



Risk Assessment Workbench Requirements

Below is a technology-neutral requirements breakdown based on the document. I have ignored the proposed technology stack and focused on business capabilities, workflow stages, functional requirements, non-functional requirements, and acceptance criteria.

1. Scope and Principles

The system should support the complete process:

Business Request → Intake → Evidence Collection → Risk Identification → Inherent Risk Assessment → Control Assessment → Residual Risk → Human Review → Committee Decision → Audit

The system must:

- Assist users rather than make the final decision automatically.
- Keep AI-generated and human-approved assessments separate.
- Use configurable risk methodologies.
- Make every rating, change, decision, and source traceable.
- Prevent unsupported or incomplete assessments from progressing.
- Support multiple products, customer segments, geographies, channels, and business changes.

Stage 1: Business Request Intake

Objective

Allow a business or product owner to submit a new financial-crime risk assessment request.

Requirements

R1.1 Create assessment request

The system shall allow an authorized user to create a new assessment request.

The request should include:

- Assessment title.
- Business change type.

- Product or service name.
- Business description.
- Business owner.
- Legal entity or business unit.
- Customer segment.
- Countries and jurisdictions involved.
- Delivery channels.
- Expected transaction volume and value.
- Transaction types.
- Use of third parties or vendors.
- Technology or process changes.
- Expected launch or implementation date.
- Supporting documents.

R1.2 Support different change types

The system shall support at least the following request types:

- New product.
- New service.
- New customer segment.
- New country or geography.
- Process change.
- Technology change.
- Third-party introduction.
- Transaction-limit or channel change.
- Periodic reassessment.

R1.3 Save draft requests

Users shall be able to save a request as a draft and return to complete it later.

R1.4 Validate mandatory information

The system shall identify missing mandatory fields before allowing the request to be submitted.

R1.5 Assign a unique assessment ID

Each submitted assessment shall receive a unique identifier that remains unchanged throughout its lifecycle.

Acceptance criteria

- Given an authorized business user, when they complete the required fields, then they can submit a new assessment.
- Given missing mandatory information, when the user attempts to submit, then the system displays the missing fields.
- Given a saved draft, when the user returns later, then the previously entered information is retained.
- Given a submitted assessment, then the system creates a unique ID, submission date, submitter, and initial status.
- Given an unsupported or incomplete change type, then the system prevents submission or requires an authorized override.

Stage 2: Document and Evidence Management

Objective

Collect, classify, validate, and manage evidence required for the assessment.

Requirements

R2.1 Upload supporting documents

Users shall be able to upload documents such as:

- Business requirement documents.
- Product specifications.
- Process maps.
- Customer information.
- Vendor documents.
- Control descriptions.
- Regulatory or policy references.
- Previous assessments.

R2.2 Classify documents

Each document shall have metadata including:

- Document type.
- Document owner.
- Source.
- Version.
- Effective date.
- Expiry date, if applicable.
- Confidentiality classification.
- Upload date.

R2.3 Extract information from documents

The system shall extract relevant information from uploaded documents and present the extracted values for user confirmation.

R2.4 Show evidence provenance

For every extracted or AI-generated statement, the system should show:

- Source document.
- Page, section, or location where available.
- Extraction date.
- Confidence or reliability indicator.
- Whether the information was confirmed by a user.

R2.5 Identify missing evidence

The system shall identify missing information and evidence required for the assessment.

Examples include:

- Missing countries.
- Missing transaction volumes.
- Missing customer information.
- Missing vendor controls.
- Missing beneficial ownership information.
- Missing monitoring arrangements.

R2.6 Manage document versions

The system shall retain previous document versions and identify which version was used for an assessment.

Acceptance criteria

- Given a valid document, when a user uploads it, then the document is stored against the correct assessment.
- Given an uploaded document, when extraction is completed, then extracted fields are displayed for review.
- Given extracted information that is incorrect, when a user changes it, then the original extracted value and corrected value are retained.
- Given a risk conclusion supported by a document, when the user views the conclusion, then the supporting source is available.
- Given an expired or superseded document, then the system warns the user before it is used as current evidence.
- Given missing evidence, then the system creates a visible information request or assessment issue.

Stage 3: Intake Validation and Structuring

Objective

Convert submitted information into a structured business and product profile.

Requirements

R3.1 Create a structured assessment profile

The system shall maintain structured fields for:

- Product or service.
- Customer type.
- Customer segment.
- Business activity.
- Countries.
- Transaction origin and destination.
- Delivery channels.
- Transaction volume.
- Transaction value.
- Transaction frequency.

- Payment methods.
- Onboarding approach.
- Third-party involvement.
- Technology dependencies.
- Ownership and entity structure.

R3.2 Detect inconsistencies

The system shall identify contradictions between:

- Form responses.
- Uploaded documents.
- Extracted information.
- Previously submitted information.

R3.3 Require business-owner confirmation

The business or product owner shall confirm that the structured profile accurately represents the proposed change.

R3.4 Preserve the original submission

The original request must remain available even after corrections or updates.

Acceptance criteria

- Given information from multiple sources, when the system detects conflicting values, then it highlights the conflict.
- Given an extracted profile, when the business owner confirms it, then the profile is marked as validated.
- Given an unconfirmed profile, then the assessment cannot proceed to final risk calculation.
- Given a change to the profile after validation, then the system records the user, time, changed fields, and reason.

Stage 4: Risk Factor Identification

Objective

Identify the risk categories and detailed indicators relevant to the proposed change.

Requirements

The system shall assess, where applicable:

1. Product or service risk.
2. Customer or segment risk.
3. Geographic risk.
4. Delivery-channel risk.
5. Transaction or activity risk.
6. Technology or new-development risk.
7. Third-party or vendor risk.
8. Ownership or entity-complexity risk.
9. Financial-crime typology risk.
10. Control-environment risk.

R4.1 Identify relevant risk categories

The system shall identify which risk categories apply to the request.

R4.2 Capture detailed risk indicators

The system shall allow users to assess detailed indicators, including:

- Cross-border capability.
- Cash access.
- Anonymity.
- Multiple currencies.
- Unknown-party payments.
- Remote onboarding.
- Transaction velocity.
- Transaction value and volume.
- Complex ownership structures.
- Sanctions exposure.
- Third-party dependencies.
- Data and monitoring limitations.

R4.3 Explain why a factor applies

For each identified risk factor, the system shall provide a rationale.

R4.4 Identify potential misuse

The system shall allow the assessment to describe how the product or change could be misused.

Examples:

- Movement of illicit funds across jurisdictions.
- Sanctions evasion.
- Fraudulent use of remote onboarding.
- Concealment of beneficial ownership.
- Use of third parties to bypass controls.

R4.5 Allow manual additions

Analysts shall be able to add a risk factor that was not identified automatically.

Acceptance criteria

- Given a cross-border payment product, then geographic, product, transaction, and sanctions-related factors are considered.
- Given a remote digital channel, then channel and authentication risks are considered.
- Given a third-party processor, then third-party risk is included.
- Given an automatically identified factor, then the system displays the reason for its inclusion.
- Given a missing risk factor, then an analyst can add it manually with a rationale.
- Given an excluded category, then the user must provide a reason for excluding it.

Stage 5: Evidence and Policy Retrieval

Objective

Provide reliable evidence supporting identified risks and controls.

Requirements

R5.1 Search approved sources

The system shall search approved internal and external sources, such as:

- Internal policies.
- Procedures.
- Control standards.
- Regulatory guidance.
- Approved risk frameworks.
- Previous assessments.
- Vendor-control documentation.

R5.2 Restrict evidence sources

The system shall use only approved and accessible sources for formal assessment evidence.

R5.3 Display source references

Each evidence item shall include:

- Source name.
- Source version.
- Relevant passage.
- Publication or effective date.
- Link or document reference.
- Retrieval date.

R5.4 Distinguish evidence from interpretation

The system shall clearly distinguish:

- Direct evidence.
- Extracted information.
- System interpretation.
- Analyst commentary.
- Assumptions.

R5.5 Detect unsupported conclusions

The system shall flag risk statements that lack sufficient supporting evidence.

Acceptance criteria

- Given an identified risk, when relevant approved evidence exists, then the system displays the evidence and its source.
- Given no relevant evidence, then the system marks the risk as unsupported or requiring analyst review.
- Given outdated policy evidence, then the system warns the user.
- Given an AI-generated conclusion, then the system links it to supporting evidence or marks it as unsupported.
- The system shall not present an unverified statement as a regulatory requirement.

Stage 6: Inherent Risk Assessment

Objective

Assess risk before considering the effectiveness of existing controls.

Requirements

R6.1 Support configurable methodologies

The system shall allow authorized administrators to configure:

- Risk factors.
- Factor weights.
- Likelihood scales.
- Impact scales.
- Scoring ranges.
- Risk bands.
- Thresholds.
- Mandatory escalation rules.
- Required approvals.

R6.2 Calculate risk deterministically

The system shall calculate scores using configured rules rather than relying on free-form generated text.

R6.3 Support factor-level scoring

The system shall record risk scores for each applicable factor.

R6.4 Calculate overall inherent risk

The system shall calculate the overall inherent risk from the configured factor ratings.

R6.5 Provide calculation transparency

Users shall be able to see:

- Input values.
- Applied weights.
- Calculation method.
- Thresholds.
- Final score.
- Resulting risk band.

R6.6 Prevent one-factor-only decisions

The system shall not automatically determine the overall risk solely from one factor unless an authorized mandatory escalation rule explicitly requires it.

R6.7 Record overrides

An authorized analyst shall be able to override a calculated rating, subject to providing a reason.

Acceptance criteria

- Given configured factor values, when the calculation runs, then the system produces the same result for the same inputs.
- Given a change to a factor value, then the overall score is recalculated and the previous result is retained.
- Given an analyst override, then the system records the calculated value, overridden value, user, timestamp, and reason.
- Given a critical mandatory escalation condition, then the assessment is escalated even if the numerical score is lower.
- Given an incomplete factor set, then the system prevents final calculation or clearly marks the result as provisional.

Stage 7: Control Identification and Assessment

Objective

Identify controls that address each inherent risk and evaluate their adequacy.

Requirements

R7.1 Maintain a control library

The system shall maintain controls such as:

- KYC and customer due diligence.
- Enhanced due diligence.
- Beneficial ownership verification.
- Sanctions screening.
- Transaction monitoring.
- Fraud monitoring.
- Transaction limits.
- Geographic restrictions.
- Customer-risk monitoring.
- Vendor due diligence.
- Investigation processes.
- Regulatory reporting.

R7.2 Map controls to risks

The system shall map one or more controls to each identified risk.

R7.3 Record control ownership

Each control shall include:

- Control owner.
- Performing department.
- Frequency.
- Trigger.
- Scope.
- Evidence source.
- Operating status.

R7.4 Assess control design

The system shall assess whether the control is appropriately designed to address the risk.

R7.5 Assess operating effectiveness

The system shall assess whether the control operates effectively in practice.

R7.6 Identify control gaps

The system shall identify:

- Risks without controls.
- Controls without evidence.
- Ineffective controls.
- Partially implemented controls.
- Controls that do not cover the full risk.
- Controls dependent on unavailable data.

R7.7 Record control conditions

The system shall allow users to specify required control enhancements or conditions.

Acceptance criteria

- Given an identified cross-border risk, then relevant controls such as sanctions screening and transaction monitoring can be mapped.
- Given a risk with no mapped control, then the system flags a control gap.
- Given a control with no supporting evidence, then the system marks its effectiveness as unverified.
- Given an ineffective control, then the system does not treat the related risk as fully mitigated.
- Given a control condition, then the condition is included in the final assessment and tracked to completion.

Stage 8: Residual Risk Assessment

Objective

Determine the remaining risk after considering the control environment.

Requirements

R8.1 Calculate residual risk

The system shall calculate residual risk using the configured methodology and control assessment results.

R8.2 Separate inherent and residual risk

The system shall display inherent risk and residual risk separately.

R8.3 Explain risk reduction

The system shall show how controls affected the risk rating.

R8.4 Prevent automatic elimination of risk

The system shall not reduce risk to zero solely because controls exist.

R8.5 Identify unacceptable residual risk

The system shall flag residual risk that exceeds configured tolerance levels.

R8.6 Generate recommended conditions

For elevated residual risk, the system shall recommend possible conditions, such as:

- Additional monitoring.
- Lower transaction limits.
- Geographic restrictions.
- Enhanced due diligence.
- Additional vendor controls.
- Periodic reassessment.
- Management approval.

Acceptance criteria

- Given a high inherent risk and partially effective controls, then residual risk remains elevated.
- Given an ineffective control, then the residual-risk calculation reflects the control weakness.
- Given residual risk above the approved tolerance, then escalation is required.
- Given recommended conditions, then an analyst can accept, modify, or reject them with a reason.

- The system shall display the difference between calculated and human-confirmed residual risk.

Stage 9: Assessment Draft Generation

Objective

Produce a structured, decision-ready assessment.

Requirements

The assessment shall contain:

- Executive summary.
- Business-change description.
- Validated business profile.
- Applicable risk categories.
- Detailed risk indicators.
- Risk statements.
- Inherent-risk scores.
- Evidence and source references.
- Mapped controls.
- Control effectiveness.
- Residual-risk scores.
- Risk gaps.
- Assumptions.
- Missing information.
- Recommended conditions.
- Analyst recommendation.
- Required approvals.

R9.1 Generate structured output

The system shall generate the assessment using defined fields and sections rather than only free-form text.

R9.2 Show uncertainty

The system shall identify:

- Low-confidence information.
- Unsupported conclusions.
- Conflicting evidence.
- Assumptions.
- Missing documents.
- Unresolved questions.

R9.3 Permit editing

Authorized analysts shall be able to edit the generated assessment.

R9.4 Track generated content

The system shall record:

- Generation date.
- Generation method or model version.
- Configuration version.
- Source evidence used.
- User who accepted or modified the content.

Acceptance criteria

- Given a completed risk and control analysis, then the system generates all required assessment sections.
- Given incomplete evidence, then the assessment clearly identifies the missing information.
- Given a generated risk statement, then the user can view the evidence supporting it.
- Given an analyst edit, then the original generated content is retained.
- Given a high-risk assessment, then the system includes the required escalation and review sections.

Stage 10: FCRM Analyst Review

Objective

Allow a qualified analyst to validate, challenge, and approve the assessment for committee review.

Requirements

R10.1 Review all assessment components

The analyst shall be able to review:

- Intake information.
- Evidence.
- Risk factors.
- Scores.
- Risk rationale.
- Control mappings.
- Residual risk.
- Conditions.
- Missing information.

R10.2 Modify AI-generated values

The analyst shall be able to change:

- Extracted fields.
- Risk categories.
- Factor ratings.
- Risk rationale.
- Control mappings.
- Control effectiveness.
- Residual risk.
- Recommended conditions.

R10.3 Capture reason for change

Every material change shall require a reason.

R10.4 Compare AI and human values

The system shall display:

- Original AI value.
- Human-confirmed value.
- Difference.
- Analyst reason.
- Date and user.

R10.5 Request more information

The analyst shall be able to return the assessment to the business owner or another team for clarification.

R10.6 Add review comments

Reviewers shall be able to add comments linked to a specific risk, control, document, or assessment section.

Acceptance criteria

- Given a generated assessment, an authorized analyst can review every section before submission.
- Given a changed rating, the system requires an override reason.
- Given an unresolved analyst comment, the assessment cannot proceed to final approval unless an authorized user explicitly accepts the exception.
- Given a request for clarification, the assessment status changes to “Information Requested.”
- Given an analyst override, the original value remains visible.

Stage 11: Conditional Challenge Review

Objective

Perform additional scrutiny when the assessment meets predefined challenge conditions.

Trigger conditions

The challenge review should run when:

- Risk is high or critical.
- Evidence is missing.
- Contradictions exist.
- Confidence is low.
- Important risk factors are missing.
- Human and system ratings differ materially.
- Controls are weak or unsupported.
- Residual risk exceeds tolerance.
- The change involves a new high-risk jurisdiction or technology.

Requirements

R11.1 Configure challenge triggers

Authorized users shall be able to configure challenge conditions.

R11.2 Identify missing risks

The challenge review shall identify risk categories or indicators that may have been overlooked.

R11.3 Identify unsupported conclusions

The challenge review shall identify conclusions that do not have adequate evidence.

R11.4 Identify contradictions

The challenge review shall compare the assessment profile, documents, evidence, and ratings for inconsistencies.

R11.5 Produce challenge findings

Each finding shall include:

- Finding description.
- Related assessment section.
- Severity.
- Supporting evidence.
- Recommended action.
- Resolution status.

R11.6 Require resolution

High-severity challenge findings must be resolved or explicitly accepted by an authorized user before committee review.

Acceptance criteria

- Given a critical-risk assessment, then challenge review is automatically triggered.
- Given missing evidence, then the challenge review creates a finding.
- Given contradictory transaction volumes in two documents, then the contradiction is highlighted.
- Given an unresolved high-severity finding, then the assessment cannot be submitted to the committee.
- Given an accepted challenge finding, then the accepting user, reason, and timestamp are recorded.

Stage 12: Risk Committee Decision

Objective

Allow the committee to make and record the final decision.

Requirements

R12.1 Support decision outcomes

The committee shall be able to select:

- Approve.
- Approve with conditions.
- Defer.
- Reject.

R12.2 Display a decision package

The committee shall receive:

- Executive summary.
- Inherent and residual risk.
- Main risk drivers.
- Control gaps.
- Evidence.
- Analyst recommendation.
- Challenge findings.
- Conditions.
- Open issues.
- Assessment history.

R12.3 Require decision rationale

A decision shall require a written rationale.

R12.4 Support conditional approval

For conditional approval, the committee shall be able to define:

- Condition.
- Owner.
- Due date.

- Priority.
- Completion evidence.
- Status.

R12.5 Prevent unauthorized final decisions

Only authorized committee members or delegated approvers may make the final decision.

R12.6 Record dissent or abstention

The system should support committee members recording:

- Approval.
- Dissent.
- Abstention.
- Comments.

Acceptance criteria

- Given a review-ready assessment, authorized committee members can view the full decision package.
- Given an approval, the system requires the required rationale.
- Given “Approve with Conditions,” at least one condition, owner, and due date are required.
- Given a rejected assessment, the rejection reason is mandatory.
- Given a final decision, the assessment becomes read-only except through a controlled amendment process.
- The system records all committee decisions and comments.

Stage 13: Conditions and Remediation Tracking

Objective

Track actions required before or after implementation.

Requirements

R13.1 Create action items

The system shall create action items for:

- Control gaps.
- Committee conditions.
- Missing evidence.

- Policy exceptions.
- Vendor remediation.
- Monitoring enhancements.

R13.2 Assign ownership and due dates

Each action shall have:

- Action owner.
- Responsible department.
- Due date.
- Priority.
- Status.
- Completion evidence.

R13.3 Support escalation

Overdue actions shall be escalated according to configured rules.

R13.4 Support closure approval

Action closure shall require evidence and, where necessary, approval by an authorized reviewer.

R13.5 Link actions to risks

Every action shall be linked to the relevant risk, control, or committee condition.

Acceptance criteria

- Given a committee condition, the system creates a trackable action item.
- Given an overdue action, the owner and relevant reviewer receive an escalation.
- Given incomplete evidence, the action cannot be marked complete.
- Given a completed action, an authorized reviewer can approve or reject its closure.
- The assessment displays open and closed actions.

Stage 14: Workflow and Status Management

Objective

Control the lifecycle of every assessment.

Suggested statuses

- Draft.
- Submitted.
- Intake Validation.
- Information Requested.
- Evidence Review.
- Risk Assessment in Progress.
- Analyst Review.
- Challenge Review.
- Ready for Committee.
- Committee Review.
- Approved.
- Approved with Conditions.
- Deferred.
- Rejected.
- Closed.
- Amendment Required.

Requirements

R14.1 Enforce valid transitions

The system shall allow only permitted status transitions.

R14.2 Define role-based actions

Different roles shall have different permissions for submitting, reviewing, editing, approving, and closing assessments.

R14.3 Show current owner

Every active assessment shall display the current owner, team, and next action.

R14.4 Provide due dates

The workflow shall support target dates and service-level monitoring.

R14.5 Maintain a workflow history

Every status change shall include:

- Previous status.
- New status.
- User.
- Timestamp.
- Reason or comment.

Acceptance criteria

- Given an assessment in draft status, it cannot be approved directly.
- Given unresolved mandatory issues, it cannot move to committee review.
- Given a status transition, the system records the transition details.
- Given an assigned task, the responsible user sees it in their work queue.
- Given an overdue assessment, the system displays or sends an escalation.

Stage 15: Access Control and Segregation of Duties

Objective

Protect sensitive information and prevent inappropriate actions.

Roles may include

- Business or product owner.
- FCRM analyst.
- FCRM reviewer.
- Risk committee member.
- Control owner.
- Evidence or policy administrator.
- System administrator.
- Auditor.
- Read-only executive user.

Requirements

R15.1 Role-based access

The system shall restrict features and information according to user role.

R15.2 Segregation of duties

The person submitting an assessment should not be able to make the final approval decision for the same assessment unless an approved exception exists.

R15.3 Restrict sensitive documents

Access to confidential documents shall be limited to authorized users.

R15.4 Support entity-level access

Users may be restricted to particular legal entities, business units, countries, or portfolios.

R15.5 Record access events

The system shall log document views, downloads, edits, approvals, and exports.

Acceptance criteria

- Given a business owner, they can submit and respond to questions but cannot finalize the committee decision.
- Given an auditor, they can view audit history but cannot modify the assessment.
- Given restricted evidence, unauthorized users cannot view or download it.
- Given a user without permission, the system prevents unauthorized actions and records the denied attempt where required.

Stage 16: Audit Trail and Explainability

Objective

Make the entire assessment reconstructable for audit and regulatory review.

Requirements

The audit trail shall capture:

- Original business request.
- Uploaded documents.
- Document versions.
- Extracted information.
- User corrections.
- Evidence retrieved.

- Risk factors considered.
- Scores and calculations.
- Configuration versions.
- AI-generated outputs.
- Human changes.
- Override reasons.
- Control mappings.
- Challenge findings.
- Comments.
- Status transitions.
- Committee decisions.
- Conditions and remediation.
- Model and prompt versions, if applicable.
- Timestamps and user identities.

R16.1 Immutable history

Completed assessment history shall not be silently modified or deleted.

R16.2 Explain every rating

The system shall provide a clear explanation of how each rating was determined.

R16.3 Export audit package

Authorized users shall be able to export a complete assessment package containing all relevant evidence and history.

R16.4 Retention management

The system shall support configured retention periods and legal holds.

Acceptance criteria

- Given a completed assessment, an auditor can reconstruct the full decision path.
- Given a changed score, the previous score, new score, user, timestamp, and reason are available.
- Given a final decision, the supporting evidence and committee rationale remain accessible.
- Given an audit export, it contains the assessment, evidence references, calculations, decisions, and history.
- No completed assessment history can be deleted without a controlled, logged process.

Stage 17: Reporting and Monitoring

Objective

Provide operational, risk, governance, and AI-performance reporting.

Requirements

R17.1 Operational reporting

The system shall report:

- Number of assessments.
- Assessments by status.
- Average completion time.
- Overdue assessments.
- Assessments by business unit.
- Assessments by risk band.
- Open conditions.
- Deferred and rejected assessments.

R17.2 Risk reporting

The system shall report:

- High and critical risks.
- Main risk drivers.
- Risk by geography.
- Risk by product.
- Risk by customer segment.
- Risk by channel.
- Risk by typology.
- Control gaps.
- Residual risk above tolerance.

R17.3 Governance reporting

The system shall report:

- Human overrides.
- Unresolved findings.
- Exceptions.

- Approval conditions.
- Reassessment due dates.
- Policy or methodology changes.

R17.4 AI evaluation reporting

If AI capabilities are used, the system shall measure:

- AI-human agreement.
- Risk-band agreement.
- Score differences.
- Human override rate.
- Missing-risk rate.
- Evidence-groundedness.
- Control-mapping accuracy.
- Unsupported-content rate.
- Processing time.
- Model usage and cost.

Acceptance criteria

- Given a selected date range, authorized users can generate reports for that period.
- Given a high-risk portfolio, the system displays the relevant products, geographies, risks, controls, and open actions.
- Given human overrides, the system reports the original and final values with reasons.
- Given AI-generated assessments, the system stores the metrics required for evaluation.

Stage 18: Reassessment and Change Management

Objective

Keep approved assessments current when the business or risk environment changes.

Requirements

R18.1 Define reassessment triggers

Triggers may include:

- Major product change.
- New geography.
- New customer segment.

- New vendor.
- Material transaction-volume change.
- New delivery channel.
- New technology.
- Regulatory or policy change.
- Significant control failure.
- Expiry of an assessment.
- Periodic review date.

R18.2 Compare versions

The system shall compare the current assessment with the previous version.

R18.3 Reuse existing information carefully

The system may reuse prior information but shall identify its source and age.

R18.4 Require reapproval when risk changes

A material change in risk or controls shall trigger the appropriate review and approval process.

Acceptance criteria

- Given a new country added to an existing product, the system creates an amendment or reassessment request.
- Given an expired assessment, the system notifies the owner and relevant reviewer.
- Given a material change, the previous approval cannot automatically remain valid without review.
- Given a reassessment, users can compare old and new risks, controls, scores, and conditions.

Stage 19: Non-Functional Requirements

Security

- Sensitive assessment and customer information shall be protected in transit and at rest.
- Access shall be based on least privilege.
- Administrative actions shall be logged.
- Secrets and credentials shall not be stored in application code.
- The system should support data masking where required.

Performance

- Common assessment pages should load within an agreed service target.
- Risk calculations should complete promptly after inputs are submitted.
- Large document processing should provide progress status.
- Long-running processing should not block the user interface.

Reliability

- Assessment data shall not be lost if document processing or evidence retrieval fails.
- Failed processing shall be retryable.
- The system shall display processing errors clearly.
- Partial results shall be marked as incomplete.

Availability and Recovery

- The system shall support backup and recovery.
- Recovery objectives shall be defined.
- The system shall protect against accidental deletion and corruption.

Accessibility and Usability

- The interface should support keyboard navigation.
- Status, warnings, and errors should be understandable.
- Risk levels should not be represented by color alone.
- Forms should provide clear field-level validation.
- The system should support review of long assessments without losing navigation context.

Scalability

- The system should support multiple business units and legal entities.
- It should support increasing document volume and assessment volume.
- It should support configurable risk methodologies without code changes where practical.

Explainability

- The system shall distinguish facts, assumptions, recommendations, and decisions.
- Automated output shall be reviewable and traceable.
- No automated recommendation shall appear to be a final approval or rejection.

Recommended MVP Scope

For an initial implementation, prioritize:

1. Assessment creation and business-request intake.
2. Document upload and evidence tracking.
3. Structured intake validation.
4. Risk-factor identification.
5. Configurable risk scoring.
6. Control mapping.
7. Residual-risk calculation.
8. Analyst review and overrides.
9. Conditional challenge review.
10. Committee decision workflow.
11. Conditions and action tracking.
12. Complete audit trail.
13. Basic reporting.

Defer advanced capabilities such as broad regulatory-source integration, sophisticated AI evaluation dashboards, automated policy-change detection, and complex portfolio analytics until the core workflow is stable.

Key Requirement Summary

The most important business rule is:

The system may interpret information, retrieve evidence, identify risks, calculate configured scores, and prepare recommendations. It must not independently approve or reject a business change.

The final design should maintain a clear separation between:

- Automated interpretation
- Deterministic calculation
- Human review
- Committee decision
- Audit evidence

This separation is essential for explainability, governance, and defensible financial-crime risk decisions. [\cite{file:1}](#)

